

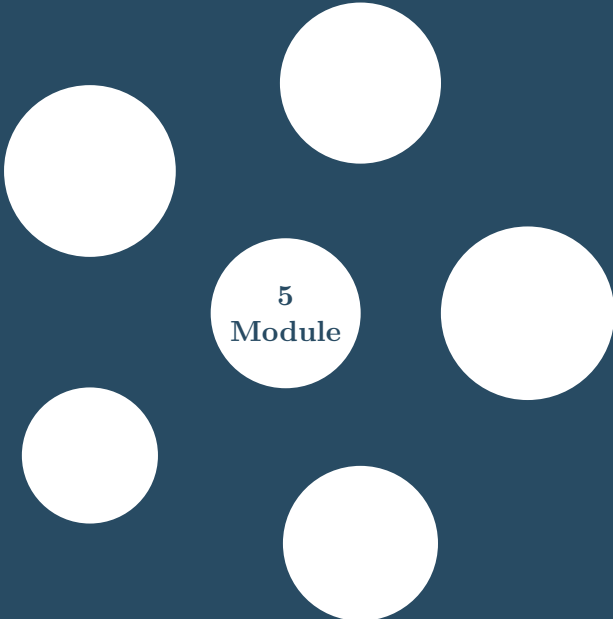
A white circle containing the text "NIS2" in a dark blue, serif font.

NIS2

NIS2 Geschäftsführer-Schulung

Alles, was die Richtlinie von einem Mitglied
des Leitungsorgans verlangt

Strukturiert nach den drei Kompetenzfeldern des BSI
und den zehn Maßnahmen aus Artikel 21

A diagram consisting of six white circles arranged in a hexagonal pattern. The central circle contains the text "5 Module" in a dark blue, serif font. The other five circles are empty.

5
Module

Über dieses Buch

Dieses Buch ist eine druckfertige Version der NIS2-Schulung für Leitungsorgane, verfügbar unter www.nisd2.eu. Es folgt den drei Kompetenzfeldern nach Artikel 20(2): Risiken erkennen, die Maßnahmen bewerten und verstehen, wie sich Risiken auf die Dienste des Unternehmens auswirken.

Keine Rechtsberatung. Dieses Material vermittelt die EU-Richtlinie und die dahinterstehenden Konzepte. Es ist keine Rechtsberatung, und keine Stelle in der EU zertifiziert derzeit NIS2-Trainer oder Schulungsprogramme.

Deutscher Standard. Der Kurs bezieht sich auf die deutsche Umsetzung – BSIG und BSI – weil Deutschlands Transposition die strengste in der EU ist.

Bestehensschwelle. Jedes Quiz erfordert 75 % zum Bestehen.

© NISD2. Alle Rechte vorbehalten.

Inhaltsverzeichnis

Über diesen Kurs	7
1 Das Gesetz	9
1.1 1.1 Was NIS2 ist und warum es existiert	9
1.2 1.2 Wer betroffen ist – Wesentliche vs. wichtige Einrichtungen	11
1.3 1.3 Bußgelder und das Tätigkeitsverbot nach Artikel 34	12
1.4 1.4 Die Registrierungspflicht	13
1.5 1.5 Ihre Pflicht zur Genehmigung und Aufsicht	14
1.6 1.6 Ihre Schulungspflicht	15
1.7 1.7 Persönliche Haftung nach nationalem Gesellschaftsrecht	15
1.8 1.8 Die Business Judgment Rule schützt Sie nicht	16
1.9 1.9 Die zehn Maßnahmen – Überblick	16
1.10 1.10 Allgefahrenansatz und Stand der Technik	17
1.11 1.11 Die Meldekaskade und erhebliche Vorfälle	18
1.12 1.12 Die Kundenbenachrichtigungspflicht	18
2 Risiko und die 10 Maßnahmen	19
2.1 2.1 Risiko = Wahrscheinlichkeit × Auswirkung	19
2.2 2.2 Was ist ein Asset?	20
2.3 2.3 Risikobehandlungsoptionen und Risikobereitschaft	20
2.4 2.4 Warum Risikomanagement kontinuierlich ist	20
2.5 2.5 Die CIA-Triade und Geschäftsauswirkungen	21
2.6 2.6 Maßnahme 1 – Risikoanalyse und Informationssicherheitsrichtlinien	21
2.7 2.7 Maßnahme 2 – Vorfallbehandlung	22
2.8 2.8 Maßnahme 3 – Geschäftskontinuität	22
2.9 2.9 Maßnahme 4 – Lieferkettensicherheit	23
2.10 2.10 Maßnahme 5 – Beschaffung, Entwicklung und Wartung	23
2.11 2.11 Maßnahme 6 – Wirksamkeitsbewertung	23
2.12 2.12 Maßnahme 7 – Cyberhygiene und Schulung	23
2.13 2.13 Maßnahme 8 – Kryptografie	24
2.14 2.14 Maßnahme 9 – Personalsicherheit, Zugangskontrolle und Asset-Management	24
2.15 2.15 Maßnahme 10 – Multi-Faktor-Authentifizierung und gesicherte Kommunikation	24
3 Entscheidungshilfe	27
3.1 3.1 Die Fragen, die jeder CEO beantworten muss	27
3.2 3.2 Unterzeichnung in der Praxis	28
3.3 3.3 Wann erneut zu unterzeichnen ist	29
3.4 3.4 Warnsignale im Unterzeichnungsprozess Ihres Teams	29
3.5 3.5 Was Sie nicht delegieren können – Die Checkliste	30
3.6 3.6 CISO- und Aufsichtsrat-Berichtslinien	31

3.7	3.7	Was bei einer Aufsichtsbehördenprüfung passiert	31
3.8	3.8	Szenario – Ransomware trifft Freitagabend	32
3.9	3.9	Szenario – Lieferanteneinbruch betrifft Ihre Kundendaten	32
3.10	3.10	Szenario – Phishing-Erfolg: Erheblich oder nicht?	32
3.11	3.11	Szenario – Lückenentdeckung vor der Prüfung	33
4		Schutz	35
4.1	4.1	Versicherung ist kein Ersatz für Kontrollen	35
4.2	4.2	D&O-Versicherung – Was sie abdeckt und Cyber-Ausschlüsse	35
4.3	4.3	Cyber-Versicherung vs. D&O – Verschiedene Produkte, verschiedener Schutz	36
4.4	4.4	Häufige Police-Ausschlüsse – Worauf zu achten ist	36
4.5	4.5	Die ersten 48 Stunden der Krisenkommunikation	36
4.6	4.6	Entscheidungen über Lösegeldzahlungen	37
5		Abschluss	39
5.1	5.1	Ihre ersten 90 Tage nach diesem Kurs	39
5.2	5.2	Abschlusszertifikat	40
A		Antwortschlüssel	41
B		Die nicht delegierbare Checkliste	43
C		Die elf Pflichtrichtlinien	45
D		Die BSI-Leitfragen für Geschäftsführer	47
E		Glossar der Schlüsselbegriffe	49
		Über NISD2	51

Über diesen Kurs

EU-Recht verpflichtet jedes Mitglied des Leitungsorgans eines betroffenen Unternehmens persönlich zur Cybersicherheitsschulung. Nicht Ihren CISO. Nicht Ihren IT-Leiter. **Sie.** Artikel 20(2) der NIS2-Richtlinie, in nationales Recht jedes EU-Mitgliedstaats umgesetzt, spricht das Leitungsteam direkt an.

Für wen dieser Kurs ist

Wenn Sie dem Leitungsteam eines von NIS2 betroffenen Unternehmens als Geschäftsführer, Vorstandsmitglied, COO, CFO oder in einer anderen Rolle angehören, die das Gesetz als “Mitglied des Leitungsorgans” bezeichnet, ist dieser Kurs für Sie. Das Gesetz unterscheidet nicht zwischen dem CEO und dem übrigen Leitungsteam. **Die Schulungspflicht ist nicht delegierbar.** Sie können nicht Ihren CISO, Ihren Anwalt oder Ihre Assistenz an Ihrer Stelle schicken.

Was dieser Kurs ist

Siebenundvierzig kurze Lektionen. Etwa vier Stunden Inhalt. Nach jeder Lektion folgt ein kurzes Quiz. Der Kurs folgt den drei Kompetenzfeldern, die das Gesetz vorschreibt:

- **Risiken erkennen** – die Bedrohungen verstehen, denen Ihr Unternehmen ausgesetzt ist
- **Maßnahmen bewerten** – beurteilen, ob das, was Ihr Team eingeführt hat, tatsächlich funktioniert
- **Serviceauswirkungen verstehen** – Cybersicherheit mit Ihrem Geschäftsbetrieb verknüpfen

Was dieser Kurs nicht ist

Dieser Kurs ist keine Rechtsberatung. Keine Qualifikation. Keine Stelle in der EU zertifiziert derzeit NIS2-Schulungsprogramme.

Wie Sie diesen Kurs nutzen

Arbeiten Sie jede Lektion der Reihe nach durch. Machen Sie nach jeder Lektion das Quiz. Halten Sie ein Notizbuch bereit. Wenn eine konkrete Anforderung auftaucht, schreiben Sie sie auf. Am Ende haben Sie Ihre eigene Aktionsliste.

Wichtige Erkenntnisse

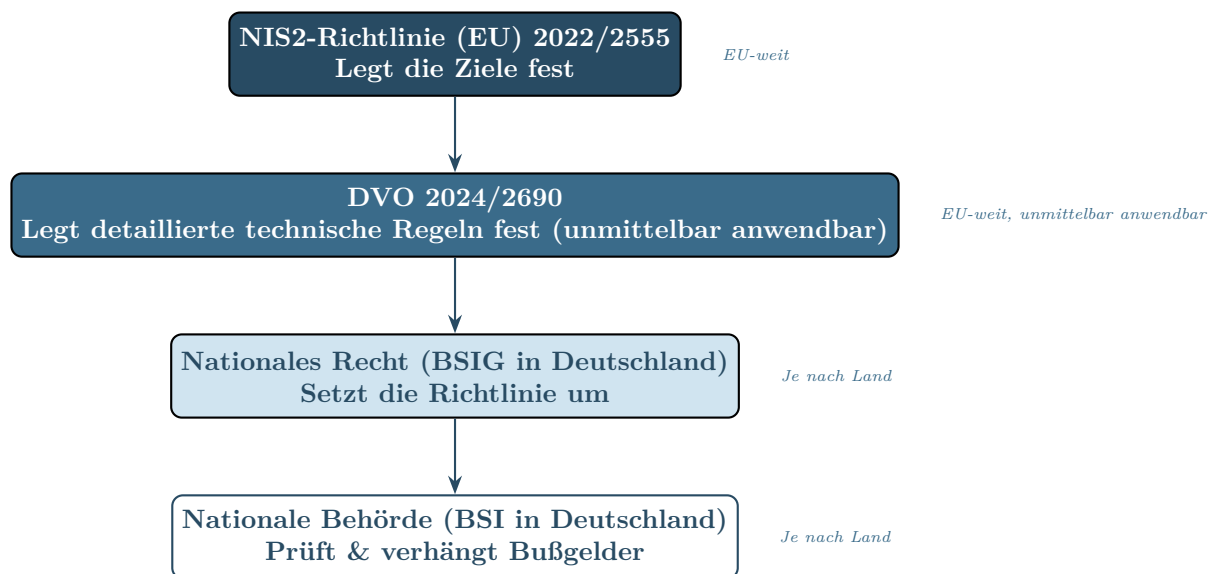
1. Artikel 20(2) verpflichtet persönlich jedes Mitglied des Leitungsorgans zur Cybersicherheitsschulung – die Pflicht ist nicht delegierbar.
2. Keine EU-Stelle zertifiziert NIS2-Schulungen; der Prüfer beurteilt die Angemessenheit anhand der behandelten Inhalte, der Zeit und der Dokumentation.
3. Dieser Kurs deckt alle drei gesetzlich geforderten Kompetenzfelder ab.

Kapitel 1

Das Gesetz

Modul 1 – 12 Lektionen

Dieses Modul legt das rechtliche Fundament von NIS2 dar: was das Gesetz ist, für wen es gilt, was es von Ihnen persönlich verlangt und was passiert, wenn Sie es nicht einhalten. Am Ende können Sie die fünf Grundlagenfragen beantworten, die das BSI von jedem betroffenen CEO erwartet.



Die vollständige Rechtskette von der EU-Richtlinie zur nationalen Durchsetzung.

1.1 **1.1** Was NIS2 ist und warum es existiert

Etwa 160.000 Unternehmen in der EU stehen auf einer Liste, die die EU für zu wichtig hält, um auszufallen. Wenn Ihr Unternehmen auf dieser Liste steht, werden die Regeln für Ihre Cybersicherheit nicht mehr von Ihnen festgelegt – sie werden durch drei Ebenen des EU- und nationalen Rechts bestimmt, die von einem nationalen Aufseher durchgesetzt werden.

Die Richtlinie

Der offizielle Name lautet Richtlinie (EU) 2022/2555 – die **NIS2-Richtlinie**. Verabschiedet am 14. Dezember 2022, in Kraft getreten am 16. Januar 2023. Sie ersetzt NIS1, das weithin als inkonsistent und schwach durchgesetzt galt – kaum jemals wurden unter NIS1 Bußgelder verhängt.

NIS2 ist eine **Richtlinie**, keine Verordnung. Eine Verordnung (wie die DSGVO) gilt unmittelbar in jedem Land. Eine Richtlinie gibt vor, welches Ergebnis jedes Land erreichen muss, und jedes Land erlässt sein eigenes nationales Recht. Die Richtlinie ist der Mindeststandard, nicht die Obergrenze.

Die Durchführungsverordnung (DVO)

Die Durchführungsverordnung (EU) 2024/2690 gilt als Verordnung unmittelbar in allen 27 Mitgliedstaaten ohne Umsetzung. Die DVO legt die detaillierten technischen Anforderungen fest: was als erheblicher Vorfall gilt, welche Richtlinien Sie haben müssen, welche Schwellenwerte die Meldepflicht auslösen.

Der Vollzug

In Deutschland: das BSIG (IT-Sicherheitsgesetz) und das BSI (Bundesamt für Sicherheit in der Informationstechnik). Das BSI kann prüfen, Registrierung fordern, Vorfallmeldungen verlangen und Bußgelder bis zu **10 Mio. € oder 2 % des globalen Umsatzes** verhängen.

Wichtige Erkenntnisse

1. NIS2 ist Richtlinie (EU) 2022/2555 – ein EU-weites Cybersicherheitsgesetz, das etwa 160.000 Einrichtungen erfasst.
2. Drei Rechtsebenen gelten: die NIS2-Richtlinie (Ziele), die DVO 2024/2690 (detaillierte technische Regeln, unmittelbar anwendbar) und das nationale Recht (BSIG in Deutschland), das das BSI durchsetzt.
3. Die Richtlinie begründet persönliche Verantwortlichkeit für das Leitungsorgan – deshalb wird das Führungsteam, nicht nur die IT, direkt angesprochen.

Quiz

F1. Was ist der Unterschied zwischen einer EU-Richtlinie und einer EU-Verordnung?

- A. Eine Richtlinie gilt unmittelbar; eine Verordnung muss in nationales Recht umgesetzt werden
- B. Eine Verordnung gilt unmittelbar; eine Richtlinie muss in nationales Recht umgesetzt werden
- C. Es gibt keinen Unterschied; beide gelten unmittelbar
- D. Eine Richtlinie gilt nur für wesentliche Einrichtungen; eine Verordnung gilt für alle

Eine Verordnung (wie die DSGVO oder die DVO) gilt unmittelbar in jedem Land. Eine Richtlinie gibt vor, welches Ergebnis erreicht werden muss, und jedes Land erlässt sein eigenes nationales Recht.

F2. Was bewirkt die DVO (Durchführungsverordnung 2024/2690)?

- A. Sie ersetzt die NIS2-Richtlinie vollständig
- B. Sie legt die Ziele fest, die jedes Land erreichen muss
- C. Sie legt detaillierte technische Anforderungen fest, die unmittelbar in allen 27 Mitgliedstaaten gelten
- D. Sie benennt die zuständige Behörde in jedem Land

Die DVO ist eine Verordnung, die unmittelbar in allen Mitgliedstaaten gilt und detaillierte technische Anforderungen festlegt.

F3. Wie lautet die vollständige Rechtskette?

- A. DVO legt Ziele fest, NIS2 legt Regeln fest, nationales Recht setzt durch
- B. NIS2-Richtlinie legt Ziele fest, DVO legt detaillierte technische Regeln fest, nationales Recht setzt um, nationale Behörde prüft
- C. Nationales Recht legt Ziele fest, NIS2-Richtlinie legt Regeln fest, DVO setzt durch
- D. DSGVO legt Ziele fest, NIS2 legt Regeln fest, DVO setzt durch

F4. Warum wurde NIS1 ersetzt?

- A. NIS1 war zu streng und kostspielig für Unternehmen
- B. NIS1 galt nur für Anbieter digitaler Infrastrukturen
- C. NIS1 wurde weithin als inkonsistent und schwach durchgesetzt angesehen – kaum jemals wurden Bußgelder verhängt
- D. NIS1 war eine Verordnung, die nicht an lokales Recht angepasst werden konnte

Unter NIS1 wurden in der gesamten EU kaum jemals Bußgelder verhängt. NIS2 wurde entwickelt, um dies zu ändern.

1.2 **1.2** Wer betroffen ist – Wesentliche vs. wichtige Einrichtungen

Artikel 3 der NIS2-Richtlinie ordnet betroffene Unternehmen in zwei Listen ein.

Anhang I – Wesentliche Einrichtungen

Energie, Verkehr, Banken,
Finanzmarktinfrastrukturen,
Gesundheit, Trinkwasser,
Abwasser,
Digitale Infrastruktur,
IKT-Dienstemanagement,
Öffentliche Verwaltung,
Raumfahrt

Proaktive Aufsicht

Anhang II – Wichtige Einrichtungen

Post- und Kurierdienste,
Abfallbewirtschaftung,
Chemikalien,
Lebensmittelproduktion und
-vertrieb,
Fertigung, Digitale Anbieter,
Forschungseinrichtungen

Reaktive Aufsicht

Max. Bußgeld: 10 Mio. € oder 2 % Umsatz **Max. Bußgeld:** 7 Mio. € oder 1,4 % Umsatz

Größenschwellenwert: 50 oder mehr Beschäftigte *oder* mehr als 10 Mio. € Jahresumsatz. Wer eines dieser Kriterien erfüllt und in einem gelisteten Sektor tätig ist, ist dabei.

Der entscheidende Unterschied: Wesentliche Einrichtungen unterliegen *proaktiver* Aufsicht (Prüfung jederzeit möglich, ohne Anlass). Wichtige Einrichtungen unterliegen *reaktiver* Aufsicht (Prüfung nur bei einem Auslöser). **Die zehn Maßnahmen nach Artikel 21 gelten für beide gleichermaßen.**

Wichtige Erkenntnisse

1. NIS2 erfasst zwei Kategorien – wesentliche (Anhang I) und wichtige (Anhang II) Einrichtungen – mit einem Größenschwellenwert von 50 Beschäftigten oder 10 Mio. € Umsatz für beide.
2. Wesentliche Einrichtungen unterliegen proaktiver Aufsicht. Wichtige Einrichtungen unterliegen reaktiver Aufsicht.
3. Die zehn Maßnahmen gelten für beide Kategorien gleichermaßen – der Unterschied liegt in

der Durchsetzungsintensität, nicht im Compliance-Umfang.

Quiz

F1. Wie lautet der Größenschwellenwert für den NIS2-Anwendungsbereich?

- A. 250 oder mehr Beschäftigte oder 50 Mio. € Umsatz
- B. 50 oder mehr Beschäftigte oder mehr als 10 Mio. € Jahresumsatz
- C. 10 oder mehr Beschäftigte oder mehr als 1 Mio. € Umsatz
- D. 100 oder mehr Beschäftigte oder mehr als 25 Mio. € Umsatz

Der allgemeine Schwellenwert sind 50 Beschäftigte oder mehr als 10 Mio. € Umsatz in einem gelisteten Sektor.

F2. Was ist der wesentliche Unterschied zwischen wesentlichen und wichtigen Einrichtungen?

- A. Wesentliche Einrichtungen müssen alle zehn Maßnahmen umsetzen; wichtige nur fünf
- B. Wesentliche Einrichtungen unterliegen proaktiver Aufsicht; wichtige reaktiver Aufsicht
- C. Wichtige Einrichtungen zahlen höhere Bußgelder als wesentliche
- D. Wesentliche Einrichtungen stehen in Anhang II; wichtige in Anhang I

F3. Setzen wesentliche und wichtige Einrichtungen unterschiedliche Sicherheitsmaßnahmen um?

- A. Ja, wesentliche Einrichtungen haben strengere technische Anforderungen
- B. Ja, wichtige Einrichtungen haben zusätzliche Meldepflichten
- C. Nein, beide müssen dieselben zehn Maßnahmen nach Artikel 21 umsetzen
- D. Für wichtige Einrichtungen gelten keine Maßnahmen

1.3 1.3 Bußgelder und das Tätigkeitsverbot nach Artikel 34

Ebene 1: Unternehmensbußgeld – bis zu 10 Mio. € oder 2 % globaler Umsatz (wesentlich)

stapeln sich

Ebene 2: Tätigkeitsverbot nach Art. 34 – persönlich, jede Führungsposition

stapeln sich

Ebene 3: Gesellschaftsrecht – Unternehmen klagt Sie auf Schadensersatz

Drei Haftungsebenen. **Sie stapeln sich.** Der Aufseher kann das Unternehmen mit einem Bußgeld belegen, Ihnen persönlich ein Tätigkeitsverbot erteilen, und das Unternehmen kann Sie auf Schadensersatz verklagen – alles für dasselbe Versäumnis.

Artikel 20(1) macht dies explizit: Leitungsorgane “können für Verstöße haftbar gemacht werden.”

Artikel 34 umfasst **vorläufige Amtsenthebungen**: eine vorübergehende Absetzung *während das Verfahren noch läuft*. Sie können abgesetzt werden, bevor der Fall entschieden ist.

Wichtige Erkenntnisse

1. Das Unternehmensbußgeld ist auf 10 Mio. € oder 2 % des globalen Umsatzes begrenzt (wesentliche); 7 Mio. € oder 1,4 % für wichtige. Mitgliedstaaten können höher gehen.
2. Artikel 34 gibt dem Aufseher die Befugnis, Ihnen persönlich jede Führungsposition zu

- verbieten – einschließlich vorläufiger Absetzung während des laufenden Verfahrens.
3. Ihr nationales Gesellschaftsrecht ermöglicht es dem Unternehmen, Sie persönlich auf Schadensersatz zu verklagen – zusätzlich zu Bußgeld und Verbot.

Quiz

- F1.** Was ist das maximale Bußgeld für wesentliche Einrichtungen unter NIS2?
- A. 7 Mio. € oder 1,4 % des weltweiten Umsatzes
 - B. 10 Mio. € oder 2 % des weltweiten Jahresumsatzes, je nachdem was höher ist
 - C. 5 Mio. € oder 1 % des weltweiten Umsatzes
 - D. 20 Mio. € oder 4 % des weltweiten Umsatzes
- F2.** Was erlaubt Artikel 34 dem Aufseher?
- A. Nur das Unternehmen mit einem Bußgeld zu belegen
 - B. Einer Person jede Führungsposition zu verbieten, einschließlich vorläufiger Absetzung während des Verfahrens
 - C. Das Unternehmen dauerhaft zu schließen
 - D. Die Betriebslizenz des Unternehmens zu entziehen
- F3.** Wie viele Haftungsebenen beschreibt die Lektion?
- A. Eine: das Unternehmensbußgeld
 - B. Zwei: das Unternehmensbußgeld und das Tätigkeitsverbot
 - C. Drei: das Unternehmensbußgeld, das Tätigkeitsverbot nach Art. 34 und persönliche zivilrechtliche Haftung nach Gesellschaftsrecht
 - D. Vier: Bußgeld, Verbot, zivilrechtliche und strafrechtliche Haftung
- F4.** Wie hoch ist das maximale Bußgeld für wichtige Einrichtungen?
- A. 10 Mio. € oder 2 % des weltweiten Umsatzes
 - B. 7 Mio. € oder 1,4 % des weltweiten Umsatzes, je nachdem was höher ist
 - C. 5 Mio. € oder 1 % des weltweiten Umsatzes
 - D. Es gibt keine Obergrenze für wichtige Einrichtungen

1.4 **1.4** Die Registrierungspflicht

Artikel 27 der NIS2-Richtlinie verpflichtet betroffene Unternehmen zur **Registrierung bei der nationalen zuständigen Behörde innerhalb von drei Monaten**, nachdem sie dem NIS2-Anwendungsbereich unterliegen.

Was die Registrierung enthalten muss

Unternehmensname, Adresse, Sektor, Kontaktdaten **einschließlich eines 24/7-Vorfallkontakts**, die vom Unternehmen erbrachten Dienste, die EU-Länder, in denen diese Dienste angeboten werden, sowie (für Anbieter digitaler Infrastrukturen) IP-Adressbereiche.

Verspätete oder falsche Registrierung wird nach Artikel 32 gesondert sanktioniert – ein eigenständiger Verstoß, unabhängig von einem Cybervorfall. In Deutschland hatten bis März 2026 von geschätzten 29.500 betroffenen Unternehmen nur etwa **11.500** fristgerecht registriert.

Wichtige Erkenntnisse

1. Artikel 27 gibt Ihnen drei Monate ab dem Tag, an dem Ihr Unternehmen betroffen wird, um sich zu registrieren; die Registrierung muss einen 24/7-Vorfallkontakt enthalten.
2. Fehlende oder falsche Registrierung ist ein eigenständiger Verstoß, unabhängig von einem Cybervorfall – und der am leichtesten zu erkennende Verstoß für den Aufseher.
3. In Deutschland hatte bis März 2026 nur etwa ein Drittel der betroffenen Unternehmen fristgerecht registriert.

Quiz

F1. Wie lange hat ein Unternehmen nach Eintritt der Betroffenheit zur Registrierung?

- A. Einen Monat
- B. Drei Monate
- C. Sechs Monate
- D. Ein Jahr

F2. Ist fehlende Registrierung ein Verstoß, auch ohne Cybervorfall?

- A. Nein, ein Verstoß erfordert einen Cybervorfall
- B. Ja, es ist ein eigenständiger Verstoß nach Artikel 32, unabhängig von einem Vorfall
- C. Nur wenn der Aufseher das Unternehmen bereits geprüft hat
- D. Nur für wesentliche Einrichtungen

F3. Welcher Kontakt muss zwingend in der NIS2-Registrierung enthalten sein?

- A. Die private Handynummer des CEO
- B. Ein 24/7-Vorfallkontakt
- C. Die allgemeine E-Mail-Adresse des Unternehmens
- D. Das LinkedIn-Profil des CISO

1.5 1.5 Ihre Pflicht zur Genehmigung und Aufsicht

Artikel 20(1) der NIS2-Richtlinie: „*Die Leitungsorgane wesentlicher und wichtiger Einrichtungen genehmigen die von diesen Einrichtungen zur Einhaltung des Artikels 21 getroffenen Maßnahmen zum Cybersicherheitsrisikomanagement, überwachen ihre Umsetzung und können für Verstöße haftbar gemacht werden.*“

Drei Pflichten, jede versagt eigenständig:

- **Genehmigen** – ein formaler Rechtsakt, dokumentiert, namentlich, datiert, persönlich unterzeichnet
- **Überwachen** – eine fortlaufende Pflicht: regelmäßige Berichte Ihres Sicherheitsteams, mindestens ein formaler jährlicher Review
- **Haftbar sein** – wenn die Maßnahmen versagen und das Unternehmen mit einem Bußgeld belegt wird, können Sie persönlich zahlen

Was die meisten Leitungsteams übersehen: Sie werden erwartet, die Kontrollen, die Sie genehmigt haben, persönlich *anzuwenden*. Ein CEO, der sich selbst von den Kontrollen ausnimmt, die er genehmigt hat, verstößt direkt – ein Prüfer kann dies als Feststellung zitieren.

Wichtige Erkenntnisse

1. Artikel 20(1) begründet drei persönliche Pflichten – genehmigen, überwachen und haftbar sein – und jede kann eigenständig versagen.
2. Die Genehmigung ist ein formaler Rechtsakt: Ihr Name und Ihre persönliche Unterschrift

müssen auf dem Dokument erscheinen.

3. Sie müssen die von Ihnen genehmigten Kontrollen persönlich einhalten – sich selbst von MFA oder Schulungen auszunehmen ist ein Prüfbefund.

1.6 1.6 Ihre Schulungspflicht

Artikel 20(2): „Die Mitglieder der Leitungsorgane wesentlicher und wichtiger Einrichtungen sind verpflichtet, an Schulungen teilzunehmen [...], damit sie ausreichende Kenntnisse und Fähigkeiten erwerben, um Risiken erkennen und Praktiken des Cybersicherheitsrisikomanagements und deren Auswirkungen auf die vom Unternehmen erbrachten Dienste beurteilen zu können.“

Risiken erkennen

Bedrohungen verstehen,
denen das Unterneh-
men ausgesetzt ist

Maßnahmen bewerten

Beurteilen, ob die Kontrol-
len tatsächlich funktionieren

Serviceauswirkungen beurteilen

Cybersicherheit mit dem
Geschäftsbetrieb verknüpfen

Drei Kompetenzfelder nach Artikel 20(2). Nur eines oder zwei abzudecken erfüllt den Standard nicht.

Häufigkeit: In Deutschland bedeutet “regelmäßig” mindestens alle drei Jahre; das BSI empfiehlt jährlich. Die Schulungspflicht ist **persönlich und nicht delegierbar**.

Wichtige Erkenntnisse

1. Die Schulung muss alle drei Kompetenzfelder abdecken – nur eines oder zwei abzudecken erfüllt den Standard nicht.
2. Mindestens alle drei Jahre in Deutschland; jährlich vom BSI empfohlen. Nicht delegierbar.
3. Der Prüfer beurteilt die Angemessenheit anhand der behandelten Inhalte, der aufgewendeten Zeit und der Dokumentation – nicht anhand der ausstellenden Stelle.

1.7 1.7 Persönliche Haftung nach nationalem Gesellschaftsrecht

Ihr Unternehmen wird mit 10 Mio. € wegen eines NIS2-Verstoßes bebußt. Ihr Aufsichtsrat tagt am nächsten Morgen. Erster Tagesordnungspunkt: ob Sie persönlich auf diese 10 Mio. € verklagt werden – und nach Ihrem nationalen Gesellschaftsrecht sind sie dazu berechtigt.

In vielen EU-Ländern, darunter Deutschland, gilt bei der Direktorenhaftung die **Beweislastumkehr**. Das Unternehmen muss nicht beweisen, dass Sie nachlässig waren. **Sie müssen beweisen, dass Sie sorgfältig waren.**

Ihre Verteidigung: der datierte Genehmigungsvermerk, die Schulungsnachweise, die Sitzungsprotokolle, das Risikoregister mit Ihrer Unterschrift. Ohne diese Dokumente argumentieren Sie aus einer leeren Akte heraus.

Wichtige Erkenntnisse

1. Die EU-Richtlinie begründet die Pflicht; Ihr nationales Gesellschaftsrecht macht daraus einen persönlichen Schadensersatzanspruch, den Ihr eigenes Unternehmen gegen Sie stellen kann.
2. In Deutschland liegt die Beweislast beim Direktor: Sie müssen die Sorgfalt nachweisen.
3. Dokumentation ist Ihre einzige Verteidigung.

1.8 1.8 Die Business Judgment Rule schützt Sie nicht

Die Business Judgment Rule schützt Direktoren vor persönlicher Haftung für *unternehmerische Entscheidungen*, die in gutem Glauben getroffen wurden. Sie gilt **nicht** für gesetzliche Pflichten.

Das Prinzip heißt **Legalitätspflicht**: Ein Direktor muss geltendes Recht einhalten. Kein unternehmerisches Ermessen ist erlaubt, ob eine gesetzliche Pflicht zu befolgen ist. „Ich habe eine vernünftige unternehmerische Entscheidung getroffen, Artikel 21 nicht vollständig umzusetzen“ ist keine gültige Verteidigung.

Die SEC klagte den CISO von SolarWinds persönlich nach einem Supply-Chain-Angriff an. Die Klage stützte sich auf interne Dokumente – Slack-Nachrichten, Risikoberichte – die eine Lücke zwischen externen Aussagen und internen Meldungen zeigten. Drei Lektionen, die unmittelbar auf NIS2 zutreffen:

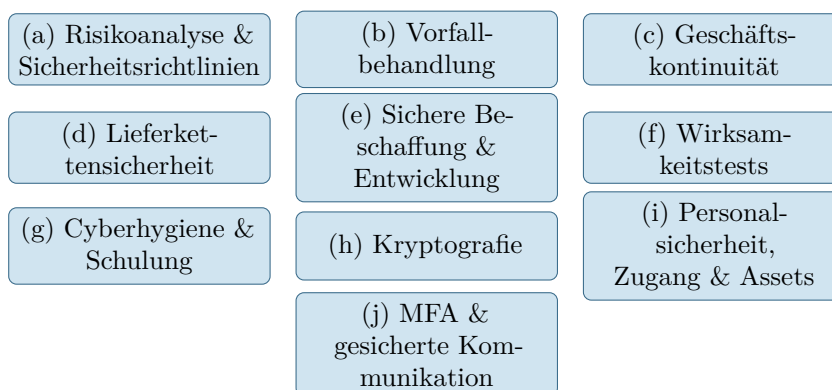
1. Interne Risikoberichte benannten Kontrollmängel, die die Führung nicht geschlossen hatte.
2. Die externe Sicherheitsdarstellung des Unternehmens wich von internen Berichten ab.
3. Risikoinformationen erreichten die Führung nicht in umsetzbarer Form.

Wichtige Erkenntnisse

1. Die Business Judgment Rule schützt kaufmännische Entscheidungen, nicht die Einhaltung von Gesetzen – Artikel 20 und Artikel 21 begründen gesetzliche Pflichten unter der Legalitätspflicht.
2. „Ich habe eine vernünftige Entscheidung getroffen, die Maßnahme nicht umzusetzen“ ist keine gültige Verteidigung.
3. Interne Dokumente – Risikoberichte, Bewertungen, Sitzungsprotokolle – sind das, was der Aufseher nutzt, um nachzuweisen, dass Sie von der Lücke wussten.

1.9 1.9 Die zehn Maßnahmen – Überblick

Es gibt **zehn** davon. Nicht acht. Nicht zwölf. Acht von zehn zu haben ist kein Bestehen.



Alle zehn gelten für jede betroffene Einrichtung. „Verhältnismäßig“ bedeutet auf Ihre Größe skaliert, nicht auf null reduziert.

Jede Kategorie benötigt drei Ebenen: **technisch**, **operativ** und **organisatorisch**. Eine Firewall ohne Richtlinie ist unvollständig. Eine Richtlinie ohne funktionierenden Prozess ist unvollständig.

Wichtige Erkenntnisse

1. Es gibt zehn spezifische Kategorien in Artikel 21(2) – alle zehn gelten für jede betroffene Einrichtung, keine ist optional.
2. „Verhältnismäßig“ bedeutet auf Ihre Größe und Risikoexposition skaliert, nicht auf null reduziert; auch ein kleines Unternehmen benötigt alle zehn.
3. Der häufige Fehler: die meisten Maßnahmen in guter Form, aber eine oder zwei vollständig fehlend. Die fehlenden sind der Verstoß.

1.10 1.10 Allgefahrenansatz und Stand der Technik

Artikel 21(1) fordert ein Risikomanagement „auf der Grundlage eines Allgefahrenansatzes, der darauf abzielt, Netz- und Informationssysteme und die **physische Umgebung** dieser Systeme vor Vorfällen zu schützen.“

Allgefahren bedeutet: Cyberangriffe, physische Einbrüche, Brände, Überschwemmungen, Stromausfälle, Lieferantenausfälle, Insider-Bedrohungen und menschliches Versagen – alles im Anwendungsbereich. Eine Risikobewertung, die nur Cyberangriffe auflistet, erfüllt den Standard nicht.

Stand der Technik bedeutet aktuelle Best Practice gemäß veröffentlichten Standards *zum Zeitpunkt der Prüfung*, nicht zum Zeitpunkt der ersten Umsetzung. Kontrollen brauchen einen Überprüfungszyklus: **mindestens jährlich**.

Wichtige Erkenntnisse

1. Allgefahren deckt alles ab, was die Systeme treffen kann – nicht nur Hacker.
2. Stand der Technik wird gegen die zum Zeitpunkt der Prüfung aktuellen Standards gemessen, nicht gegen den Zeitpunkt der ersten Umsetzung.
3. Ihre Kontrollen brauchen einen Überprüfungszyklus – die Regel lautet nicht „einmal umsetzen“, sondern „aktuell halten“.

Quiz

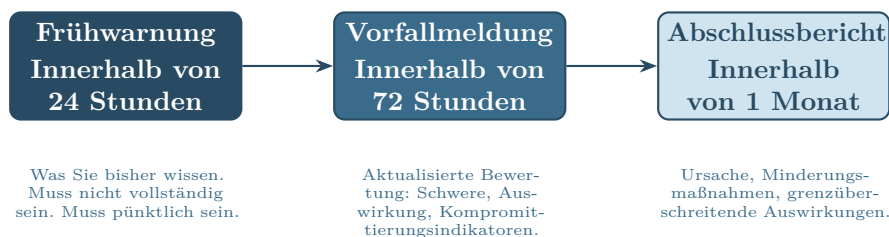
F1. Was verlangt der Allgefahrenansatz?

- A. Schutz nur gegen Cyberangriffe
- B. Schutz gegen jede Bedrohung – Cyberangriffe, physische Gefahren, Umweltereignisse, Lieferantenausfälle, Insider-Bedrohungen und menschliches Versagen
- C. Schutz nur gegen zuvor aufgetretene Bedrohungen
- D. Schutz nur gegen im Risikoregister aufgeführte Bedrohungen

F2. An welchem Zeitpunkt beurteilt der Prüfer, ob Kontrollen dem „Stand der Technik“ entsprechen?

- A. Zum Zeitpunkt der ersten Implementierung
- B. Anhand der zum Zeitpunkt der Prüfung aktuellen Standards
- C. Zum Datum des Inkrafttretens der NIS2-Richtlinie
- D. Zum Gründungsdatum des Unternehmens

1.11 1.11 Die Meldekaskade und erhebliche Vorfälle



Verspätete Meldung ist ein eigenständig sanktionierbarer Verstoß.

Ein erheblicher Vorfall nach DVO 2024/2690 liegt vor, wenn *eines* der folgenden Kriterien erfüllt ist: finanzieller Verlust von mehr als 500.000 € oder 5 % des Umsatzes (je nachdem was niedriger ist), Exfiltration von Betriebsgeheimnissen, Tod oder schwerwiegender Gesundheitsschaden, oder böswilliger unbefugter Zugang mit schwerwiegender Störung.

Artikel 4 Wiederholungsregel: Zwei oder mehr Vorfälle mit derselben Grundursache innerhalb von sechs Monaten, die zusammen den Schwellenwert überschreiten, gelten als ein erheblicher Vorfall. Grundursachen verfolgen.

Wichtige Erkenntnisse

1. Schwellenwert erheblicher Vorfall: 500.000 € oder 5 % Umsatz (je niedriger), Betriebsgeheimnisse, Tod, schwerwiegender Gesundheitsschaden oder böswilliger Zugang mit schwerwiegender Störung.
2. Zwei oder mehr Vorfälle mit derselben Grundursache innerhalb von sechs Monaten, die zusammen den Schwellenwert überschreiten, zählen als ein erheblicher Vorfall.
3. Die Kaskade: 24 h (Frühwarnung), 72 h (Meldung), 1 Monat (Abschlussbericht) – verspätete Meldung ist ein eigenständiges Bußgeld.

1.12 1.12 Die Kundenbenachrichtigungspflicht

Zwei gesonderte kundenbezogene Pflichten:

- **Artikel 23(2) – selbstaufführend:** Wenn ein erheblicher Vorfall voraussichtlich Kunden beeinträchtigt, unverzüglich benachrichtigen und mitteilen, welche Schutzmaßnahmen sie ergreifen können. Kein Aufseherbeschluss erforderlich.
- **Artikel 36 – aufseherangeordnet:** Der Aufseher kann im öffentlichen Interesse eine Kundenbenachrichtigung anordnen.

Ein Unternehmen, das auf einen Aufseherbeschluss wartet, wenn seine Kunden einer aktiven Bedrohung ausgesetzt sind, hat Artikel 23(2) bereits verletzt.

Wichtige Erkenntnisse

1. Artikel 23(2) ist selbstaufführend – wenn Kunden einer laufenden Bedrohung ausgesetzt sind, unverzüglich benachrichtigen und ihnen mitteilen, was sie tun können. Kein Aufseherbeschluss erforderlich.
2. Artikel 36 ist eine gesonderte Befugnis – auf ihn zu warten, wenn Kunden einer aktiven Bedrohung ausgesetzt sind, verletzt bereits Artikel 23(2).
3. Bereiten Sie eine vorgefertigte Kundenbenachrichtigungsvorlage und eine definierte Genehmigungskette vor, bevor ein Vorfall eintritt.

Kapitel 2

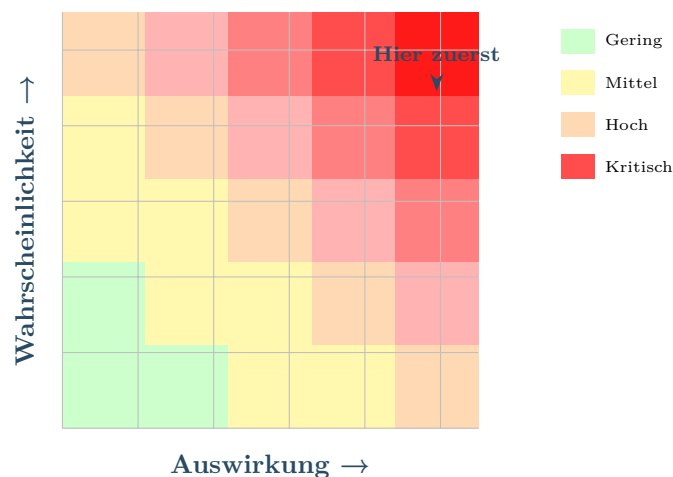
Risiko und die 10 Maßnahmen

Modul 2 – 15 Lektionen

Dieses Modul behandelt das Risikomanagement-Rahmenwerk hinter Artikel 21 und geht jede der zehn Maßnahmen im Detail durch. Am Ende können Sie die zehn Maßnahmen mit Ihrem CISO durchgehen und die richtigen Fragen zu jeder einzelnen stellen.

2.1 **2.1** Risiko = Wahrscheinlichkeit × Auswirkung

Artikel 21(1) fordert „angemessene und verhältnismäßige“ Maßnahmen zur Bewältigung von Cybersicherheitsrisiken. Wie viel Sie für Sicherheit ausgeben, muss zu Ihrer Risikoexposition passen.



Die Risikomatrix. Die obere rechte Ecke – hohe Wahrscheinlichkeit, hohe Auswirkung – ist der Ausgangspunkt der Arbeit des Leitungsorgans.

Wenn Sie Cybersicherheitsmaßnahmen genehmigen, ohne das dahinterliegende Risikobild zu verstehen, ist Ihre Unterschrift uninformatiert – und eine uninformatierte Genehmigung schützt Sie nicht nach Artikel 20(1).

Wichtige Erkenntnisse

1. Jede Risikoentscheidung unter NIS2 lässt sich auf zwei Fragen zurückführen – wie wahrscheinlich und wie schlimm.
2. Die obere rechte Ecke der Matrix ist der Ausgangspunkt der Arbeit des Leitungsorgans.
3. Das Risikoregister wandelt das Budgetargument von einer Meinung in Belege um – fordern

Sie es an und prüfen Sie, ob die Daten aktuell sind.

2.2 2.2 Was ist ein Asset?

Equifax hatte einen Patch für eine kritische Schwachstelle. Sie spielten ihn auf jeden Server auf – außer einem. Dieser eine Server stand auf keiner Liste. 147 Millionen Datensätze wurden dadurch gestohlen. Die Ursache war nicht der fehlende Patch – es war der fehlende Inventareintrag.

Ein Asset ist **alles, wovon das Unternehmen für seinen Betrieb abhängt**: Server, Laptops, Kundendatenbanken, Cloud-Abonnements, Gebäude, Lieferanten, Mitarbeiter mit kritischem Wissen und wichtige Geschäftsprozesse. Die vollständige Liste heißt **Asset-Inventar** und muss aktuell gehalten werden.

Der Prüfer fordert das Inventar *zuerst* an – vor Richtlinien, Risikomatrix oder allem anderen – weil jede andere Kontrolle nur so vollständig ist wie die Liste, die sie abdeckt.

Fragen an Ihr Team

„Zeigen Sie mir das Asset-Inventar. Wann wurde es zuletzt aktualisiert, und umfasst es Cloud-Abonnements und Auftragnehmer-Zugänge?“ Wenn die Antwort nur Server und Laptops abdeckt, ist das Inventar unvollständig.

2.3 2.3 Risikobehandlungsoptionen und Risikobereitschaft

Vier Optionen für jedes Risiko: **Vermeiden, Mindern, Übertragen, Akzeptieren**. Für NIS2-Einrichtungen ist Mindern die häufigste Option; Übertragen und Akzeptieren sind für schwerwiegende Risiken selten vertretbar.

DVO 2024/2690, Anhang 2.1.1: „Ergebnisse der Risikobewertung und Restrisiken sind von den Leitungsorganen zu akzeptieren.“ Ihre Unterschrift, datiert, auf dem Register oder dem Akzeptanzblatt. **Dies ist das am häufigsten fehlende Dokument bei Prüfungen mittelgroßer Unternehmen.**

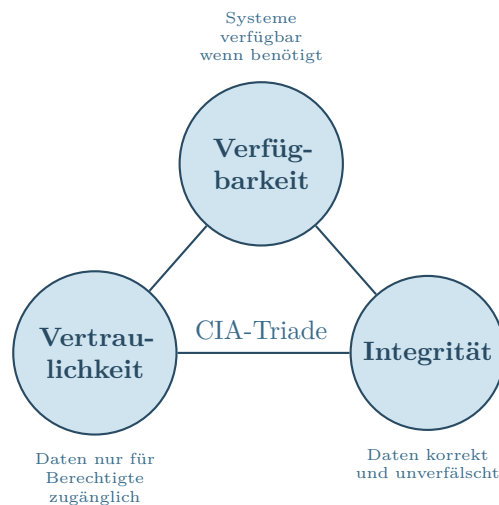
Die **Risikobereitschaft** – das Maß an Risiko, mit dem das Unternehmen insgesamt leben will – ist die Grenze des CEO, nicht die des CISO. Ohne sie wird jede Risikobehandlungsentscheidung zum Streit.

2.4 2.4 Warum Risikomanagement kontinuierlich ist

Artikel 21 sagt nicht „führen Sie eine Risikoanalyse durch“. Er sagt, Sie müssen „angemessene und verhältnismäßige“ Maßnahmen treffen – **Präsens, kontinuierlich**. Risikomanagement ist ein Zyklus, kein Projekt.

Mindestüberprüfungszyklus: **jährlich** (BSI-Standard 200-1, Abschnitt 7.4). Zusätzlich bei jedem Auslöser: schwerwiegender Vorfall, wesentliche Geschäftsänderung, neue Schwachstellenveröffentlichung, regulatorische Änderung oder Prüfbefund.

2.5 **2.5** Die CIA-Triade und Geschäftsauswirkungen



Die **Geschäftsauswirkungsanalyse (BIA)** übersetzt CIA-Kategorien in Geschäftszahlen: Wiederherstellungsziele und Geschäftsfolgen. Die Aufgabe des CEO ist nicht, die BIA zu berechnen – es ist, *die Geschäftsannahmen darin zu validieren*.

2.6 **2.6** Maßnahme 1 – Risikoanalyse und Informationssicherheitsrichtlinien

Die DVO fordert **elf separate Richtlinien**:

#	Erforderliche Richtlinie
1	Informationssicherheitsrichtlinie (übergeordnet – Ihre Unterschrift, Ihr Name)
2	Risikomanagement
3	Vorfallbehandlung
4	Lieferkettensicherheit
5	Sicherheitstests
6	Wirksamkeitsbewertung
7	Kryptografie
8	Zugangskontrolle
9	Privilegierte Konten
10	Informations- und Asset-Handling
11	Wechselmedien

Die drei am häufigsten fehlenden bei KMU: **Sicherheitstests, privilegierte Konten, Wechselmedien**.

Die übergeordnete Richtlinie muss Ihre persönliche Unterschrift tragen und in Ihrem Namen veröffentlicht sein. Sie muss **jährlich** mit einer datierten Genehmigung des Leitungsorgans überprüft werden.

Quiz

F1. Wie viele separate Richtlinien fordert die DVO für Maßnahme 1?

- A. Eine umfassende Sicherheitsrichtlinie
- B. Fünf Kernrichtlinien

- C. Elf (eine übergeordnete plus zehn themenspezifische)
- D. Drei (Risiko, Vorfall, Zugang)

F2. Welche drei themenspezifischen Richtlinien vergessen KMU am häufigsten?

- A. Risikomanagement, Vorfallbehandlung, Zugangskontrolle
- B. Sicherheitstests, privilegierte Konten, Wechselmedien
- C. Kryptografie, Lieferkette, Wirksamkeitsbewertung
- D. Backup, Notfallwiederherstellung, Krisenmanagement

2.7 2.7 Maßnahme 2 – Vorfallbehandlung

Fünf Teile eines Incident-Response-Plans: **Erkennung, Klassifizierung, Reaktion, Wiederherstellung, Lessons Learned.**

CEO-spezifische Einträge im Plan (müssen namentlich vorab zugewiesen sein):

- Krisenaustrufung
- Genehmigung von Notfallausgaben
- Genehmigung externer Kommunikation an Kunden und den Aufseher
- Entscheidung, ob ein Lösegeld gezahlt wird

Der Plan muss getestet werden. Eine **Tischübung** – eine schriftliche Probe gegen ein Szenario – durchgeführt vor weniger als 12 Monaten, mit dokumentierten Änderungen als Ergebnis.

2.8 2.8 Maßnahme 3 – Geschäftskontinuität

NotPetya-Malware löschte Maersks globale IT in unter zwei Stunden. Wiederherstellungskosten: ca. 300 Mio. €. Der einzige Grund, warum es 10 Tage dauerte statt Monate: ein Backup war zufällig wegen eines Stromausfalls in Ghana offline. Glück ist keine Kontrolle.

Drei Komponenten: **Backup-Management** (getestet, getrennt aufbewahrt), **Notfallwiederherstellung** (RTO und RPO definiert und durch tatsächliche Tests verifiziert), **Krisenmanagement** (benanntes Team, vorab zugewiesene Befugnisse, jährlich geübt).

RTO und RPO

RTO (Recovery Time Objective): Wie schnell muss dieses System nach einem Vorfall wieder laufen?

RPO (Recovery Point Objective): Wie viel Datenverlust kann das Unternehmen verkraften, gemessen in Zeit?

Sie müssen an der jährlichen Krisenübung teilnehmen. BSI DER.4 nennt das Leitungsorgan in neun von sechzehn Anforderungen – Abwesenheit ist ein Prüfbefund.

2.9 **2.9** Maßnahme 4 – Lieferkettensicherheit

Ein routinemäßiges Software-Update an 18.000 Kunden enthielt eine von Angreifern platzierte Hintertür. Jeder Kunde musste es als seinen eigenen Vorfall behandeln – nicht als den seines Lieferanten.

„Lieferant“ unter NIS2 bedeutet **jeder mit Zugang zu Ihren Systemen oder Daten** – vom Cloud-Anbieter bis zum Reinigungsunternehmen mit einem Schlüssel zum Serverraum.

Vier Anforderungen für jeden Lieferanten:

1. Inventareintrag des Lieferanten
2. Risikoklassifizierung
3. Vertragsklauseln: Vorfallbenachrichtigung, Prüfrechte, Sicherheitsbasisanforderungen
4. Regelmäßige Überprüfung (Fragebogen, Zertifikat oder Prüfung)

Wenn Ihr Lieferant angegriffen wird und Kundendaten abfließen, liegen die Meldepflicht nach Artikel 23 und die Kundenbenachrichtigungspflicht nach Artikel 36 bei **Ihnen**, nicht beim Lieferanten.

2.10 **2.10** Maßnahme 5 – Beschaffung, Entwicklung und Wartung

Drei Pflichten: **sichere Beschaffung** (Sicherheitsanforderungen bei jedem Kauf), **sichere Entwicklung** (dokumentierter Standard, wenn Sie Software schreiben), **Schwachstellenbehandlung** (Patch-SLAs auf Papier, Ergebnisse vierteljährlich verfolgt).

Das wichtigste operative Nachweisdokument: **ein schriftliches Patch-SLA und ein Quartalsbericht darüber, ob Sie es einhalten.**

Fragen an Ihr Team

„Was ist unser Patch-SLA für kritische Schwachstellen, und auf welchem Prozentsatz der Systeme haben wir es im letzten Quartal eingehalten?“

2.11 **2.11** Maßnahme 6 – Wirksamkeitsbewertung

Der **jährliche Managementreview** ist eine eigenständige Pflicht nach BSI-Standard 200-1, Abschnitt 7.4. Er muss ein **unterzeichnetes Protokoll** hervorbringen mit:

- Status des Sicherheitsprogramms seit dem letzten Review
- Ob frühere Entscheidungen umgesetzt wurden
- Neue Bedrohungen, Ressourcenbedarf, akzeptierte Restrisiken

Die erste Frage des Prüfers zu Maßnahme 6: „Zeigen Sie mir das Protokoll Ihres letzten jährlichen Managementreviews, und zeigen Sie mir, dass die Folgemaßnahmen abgeschlossen wurden.“ Ohne ein datiertes, unterzeichnetes Protokoll versagt die gesamte Maßnahme bei der Prüfung.

2.12 **2.12** Maßnahme 7 – Cyberhygiene und Schulung

Zwei Hälften: **Cyberhygiene** (tägliche Grundlagen: starke Passwörter, MFA, regelmäßige Updates, Backups, vorsichtiger Umgang mit Links) und **Schulung** (geplantes Programm).

Schulung gilt für:

- Alle Mitarbeiter: jährliche Sensibilisierungsschulung

- Technische und risikobehaftete Rollen: rollenspezifische Schulung
- Leitungsorgan: eigenes Programm nach Artikel 20(2)

Ein generischer E-Learning-Kurs für das gesamte Unternehmen erfüllt diese Anforderung nicht.

Phishing-Simulationen mit Folgeschulung für jeden, der klickt, sind Teil des Programms.

Ein CEO, der die Phishing-Simulation überspringt oder sich selbst vom Sensibilisierungsprogramm ausnimmt, hat einen **persönlichen Prüfbefund** nach BSI-Standard 200-1 Grundsatz 6 erzeugt.

2.13 2.13 Maßnahme 8 – Kryptografie

Die Kryptografierichtlinie muss **Verschlüsselung im Ruhezustand** und **Verschlüsselung bei der Übertragung** abdecken und muss benennen, wo jede gilt.

Verweisen Sie auf **BSI TR-02102** in der Richtlinie, anstatt Algorithmen namentlich festzuschreiben – die Leitlinie wird aktualisiert, wenn die Forschung sich weiterentwickelt, sodass die Richtlinie automatisch aktuell bleibt.

Schlüsselverwaltung ist der Punkt, an dem Kryptografie in der Praxis scheitert. Fragen Sie: Wo werden die Schlüssel gespeichert? Wenn die Antwort lautet „auf demselben Server wie die Daten“, ist das eine Lücke. Wer kann darauf zugreifen? Wann wurden sie zuletzt rotiert?

2.14 2.14 Maßnahme 9 – Personalsicherheit, Zugangskontrolle und Asset-Management

Der häufigste Prüfbefund: **der Austrittsschritt** – ein ehemaliger Mitarbeiter hält noch Wochen nach seinem Ausscheiden einen aktiven VPN-Login oder ein Administrator-Konto.

Der **Eintritt-Wechsel-Austritt-Prozess**: die drei Übergaben zwischen HR und IT. Wenn eine davon fehlerhaft ist, ist Maßnahme 9 fehlerhaft. Bei kritischen Rollen erfolgt die Zugangssperrung in dem Moment, in dem die Kündigung beschlossen wird – nicht am Tag, an dem die Person das Gebäude verlässt.

Privilegierte Konten benötigen eine eigene Richtlinie mit stärkeren Kontrollen und einem eigenen Überprüfungszyklus (DVO Anhang 11.3).

2.15 2.15 Maßnahme 10 – Multi-Faktor-Authentifizierung und gesicherte Kommunikation

MFA ist für vier Kategorien faktisch verpflichtend:

Fernzugriff	Administratorkon	Kritische Systeme	E-Mail
-------------	------------------	-------------------	--------

Gesicherte Notfallkommunikation: Ein Out-of-Band-Kanal, der funktioniert, wenn normale Systeme kompromittiert sind. Wenn der Krisenplan auf E-Mail angewiesen ist und E-Mail ausgefallen ist, scheitert der Plan im schlimmsten Moment.

Vorbildfunktion (BSI-Standard 200-1 Grundsatz 6): Ihr eigenes Konto ist das erste, das der Prüfer überprüft. Ein CEO, der MFA genehmigt, aber seinen eigenen Login ausgenommen hat, hat einen persönlichen Befund erzeugt.

Fragen an Ihr Team

Überprüfen Sie Ihr eigenes E-Mail-Konto heute – ist MFA aktiviert? Falls nicht, aktivieren Sie es. Zehn Minuten.

Quiz

F1. Für welche vier Kategorien ist MFA faktisch verpflichtend?

- A. Persönliche E-Mail, soziale Medien, Onlinebanking und persönliche Geräte
- B. Fernzugriff, Administratorkonten, kritische Systeme und E-Mail
- C. Marketingtools, HR-Systeme, Buchhaltungssoftware und die Unternehmenswebsite
- D. Vorstandssitzungen, Investorenportale, Pressemitteilungen und interne Chats

F2. Warum ist das Konto des CEO das erste, das der Prüfer auf MFA überprüft?

- A. Weil das Konto des CEO die sensibelsten Daten enthält
- B. Weil BSI-Standard 200-1 Grundsatz 6 verlangt, dass das Leitungsorgan die von ihm genehmigten Sicherheitskontrollen persönlich befolgt
- C. Weil der Prüfer alphabetisch beginnt
- D. Weil der Aufseher die CEO-Rolle in Artikel 21 namentlich genannt hat

Kapitel 3

Entscheidungshilfe

Modul 3 – 11 Lektionen

Dieses Modul behandelt die Governance-Entscheidungen, die nur Sie treffen können: was zu unterzeichnen ist, wann erneut zu unterzeichnen ist, wie eine Prüfung abläuft und wie mit den schwierigsten Szenarien umzugehen ist – Ransomware, Lieferanteneinbrüche und Lückenentdeckung vor der Prüfung.

3.1 **3.1** Die Fragen, die jeder CEO beantworten muss

Das BSI hat eine Liste strukturierter Fragen veröffentlicht, die jedes Leitungsorgan beantworten können muss. Dies ist der konkreteste praktische Test von Artikel 20(2), den ein EU-Aufseher je veröffentlicht hat.

Grundlagen (5 Fragen)

- 1 Weiß ich, ob mein Unternehmen unter NIS2 fällt, und verstehe ich den Anwendungsbereich des Gesetzes?
 - 2 Erfüllen unsere Risikomanagementmaßnahmen die gesetzlichen Anforderungen, und sind sie dokumentiert?
 - 3 Kann ich einen erheblichen Vorfall korrekt klassifizieren und rechtzeitig melden?
 - 4 Sind wir korrekt beim Aufseher registriert, und halten wir die Registrierung aktuell?
 - 5 Verstehe ich meine persönlichen Pflichten, Schulungsanforderungen, Haftung und die Sanktionen?
-

Die zehn Pflichtmaßnahmen (10 Unterfragen)

- 6.1 Ist unsere Risikoanalyse aktuell und auf aktuelle Bedrohungen ausgerichtet?
 - 6.2 Haben wir einen getesteten Notfallplan?
 - 6.3 Können wir aus einem Backup wiederherstellen, und ist unser Krisenmanagement getestet?
 - 6.4 Wird die Lieferantensicherheit überprüft und aktiv gemanagt?
 - 6.5 Ist Sicherheit in unsere Beschaffung, Entwicklung und Wartung von Systemen eingebaut?
 - 6.6 Messen wir die Wirksamkeit unserer Sicherheitskontrollen?
 - 6.7 Führen wir Cyberhygiene-Programme und Mitarbeiterschulungen durch?
 - 6.8 Setzen wir Kryptografie und Verschlüsselung dort ein, wo es erforderlich ist?
 - 6.9 Managen wir Personalsicherheit, Zugangskontrolle und Asset-Management?
 - 6.10 Verwenden wir Multi-Faktor-Authentifizierung und gesicherte Kommunikation?
-

Tieferegehende Prüfungen (4 Fragen)

- 7 Deckt unsere Risikoanalyse alle Assets, Bedrohungen, Schwachstellen und Schadensarten ab – einschließlich Reputations- und Regulierungsschäden?
 - 8 Bewerten wir, wie jedes Risiko Verfügbarkeit, Integrität und Vertraulichkeit sowie die finanzielle Stabilität beeinflusst?
 - 9 Berücksichtigen wir sektorspezifische Anforderungen und die wichtigsten Geschäftsprozesse?
 - 10 Führen wir Szenarioübungen durch, und habe ich persönlich an einer teilgenommen?
-

Fragen an Ihr Team

Drucken Sie diese Liste aus und gehen Sie sie mit Ihrem CISO durch. Bewerten Sie jede: **sicher / mit Hilfe / kann ich nicht beantworten**. Jede Frage in der dritten Spalte ist eine Lücke, die Ihre Schulung schließen muss.

3.2 3.2 Unterzeichnung in der Praxis

Vier Fragen, die Sie stellen müssen, bevor Sie ein Sicherheitsdokument unterzeichnen:

1. „**Zeigen Sie mir die Risikoanalyse, auf die sich diese Richtlinie bezieht – wann wurde sie zuletzt aktualisiert?**”
2. „**Was hat sich seit der letzten Version, die ich unterzeichnet habe, geändert?**”
3. „**Wurde das Budget zur Umsetzung dieser Maßnahmen genehmigt?**” Eine Richtlinie, die Kontrollen verspricht, die das Unternehmen nicht finanziert hat, ist eine Richtlinie, die der Aufseher gegen Sie verwenden wird.
4. „**Wer sind die namentlich Verantwortlichen für jede Maßnahme, und wissen sie, dass sie benannt sind?**” Nicht zugewiesene Maßnahmen sind Absichten, keine Kontrollen.

Das Leitungsorgan entscheidet **was und warum**. Der CISO entscheidet **wie**. Eine uninformierte Unterschrift ist in den meisten EU-Rechtsordnungen rechtlich wirkungslos – und vor Gericht arbeitet sie gegen Sie.

3.3 **3.3** Wann erneut zu unterzeichnen ist

Jährlich ist die Untergrenze. Sechs Ereignistypen erzwingen eine erneute Unterzeichnung vor dem Jahreszyklus:

1. Führungswechsel
2. Wesentliche Änderung des Unternehmens (Akquisition, neues Gebiet, neues Produkt)
3. Schwerwiegender Vorfall, der eine Lücke aufgedeckt hat
4. Regulatorische Änderung
5. Prüfbefund, der Abhilfe erfordert
6. Wesentliche Änderung der Lieferantenbasis

Jede erneute Unterzeichnung dokumentiert drei Dinge: das **auslösende Ereignis**, die **Änderungen an den Maßnahmen** und die **neue Unterschrift**.

3.4 **3.4** Warnsignale im Unterzeichnungsprozess Ihres Teams

Neun Sätze, die Sie dazu bringen sollten, den Stift niederzulegen:

Warnsignal	Ihre Antwort
„Das haben wir immer so gemacht.“	„Zeigen Sie mir den Versionsverlauf.“
„Unterschreiben Sie hier, das ist nur eine Formalität.“	„Wenn es eine Formalität ist, warum braucht es meine Unterschrift?“
„Unsere IT-Abteilung kümmert sich darum.“	„Ich bin die Führung. Das macht mich zur Person, die es verstehen muss.“
„Das können wir uns nicht leisten.“	„Zeigen Sie mir die Risikobewertung, die besagt, dass das ein akzeptables Restrisiko ist.“
„Wir hatten noch nie ein Problem.“	„Das ist keine Antwort. Zeigen Sie mir die aktuellen Testergebnisse.“
„Es ist dokumentiert, aber Sie können nicht darauf zugreifen.“	„Dann warte ich, bis ich es lesen kann.“
„Vertrauen Sie einfach dem Prüfer.“	„Der Prüfer hat seine Aufgabe und ich habe meine. Das hier ist meine.“
„Wir beheben das nach der Prüfung.“	„Wenn es bekannt ist, ist es bereits ein Befund. Jetzt beheben, dann unterzeichne ich die Lösung.“
„Der frühere CEO hat etwas Ähnliches unterschrieben.“	„Der frühere CEO unterschreibt das nicht. Ich schon.“

Die Regel: **Wenn die Erklärung schneller geht als das Dokument, ist der Prozess fehlerhaft.** Eine Unterzeichnung zu verweigern kostet Stunden. Blind zu unterzeichnen kostet Jahre.

3.5 3.5 Was Sie nicht delegieren können – Die Checkliste

Elf nicht delegierbare Entscheidungen, elf unterzeichnete Dokumente:

1. Genehmigung der Cybersicherheits-Risikomanagementmaßnahmen (übergeordnete Sicherheitsrichtlinie, in Ihrem Namen unterzeichnet)
2. **Formale Akzeptanz der Restrisiken** – das einzige Dokument, das die meisten CEOs nicht vorlegen können
3. Genehmigung des Sicherheitsbudgets
4. Krisenaustrufung bei einem schwerwiegenden Vorfall
5. Die Artikel 23-Meldungsentscheidung (Ihr Team entwirft, Sie genehmigen)
6. Kundenbenachrichtigungsentscheidungen nach Artikel 36
7. Genehmigung außerordentlicher Zahlungen (Ransomware, Vergleich, Notlieferant)
8. Genehmigung aller öffentlichen Erklärungen während einer Krise
9. Beauftragung externer Forensik oder Rechtsberatung bei schwerwiegenden Vorfällen
10. Lösung von Konflikten zwischen Sicherheit und anderen Geschäftsprioritäten bei Eskalation
11. Der jährliche Managementreview – formal, dokumentiert, unterzeichnet, mindestens einmal im Jahr

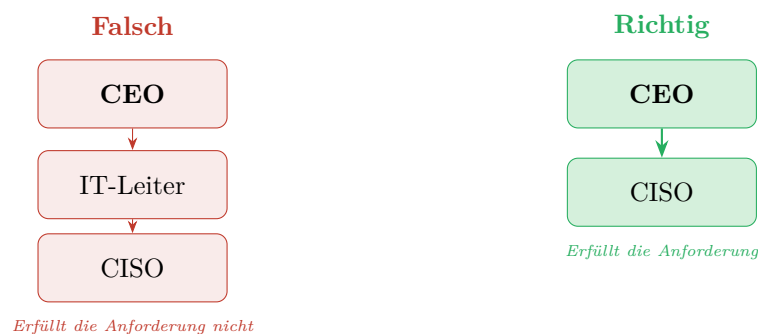
Die **Restrisikoakzeptanz** ist das am häufigsten fehlende Dokument bei Prüfungen. Jedes Risiko, mit dem das Unternehmen beschlossen hat zu leben, muss im unterzeichneten Risikoregister erscheinen – mit einer Bewertung, einer Beschreibung des Akzeptierten und einem benannten Verantwortlichen mit einem Überprüfungsdatum. Ihre Unterschrift beweist, dass

Sie persönlich überprüft haben, was das Unternehmen zu leben beschlossen hat.

3.6 **3.6** CISO- und Aufsichtsrat-Berichtslinien

DVO 2024/2690, Anhang 1.2.3: „Mindestens eine Person berichtet direkt an die Leitungsorgane in Fragen der Netz- und Informationssystemsicherheit.“

Dies ist eine **harte Anforderung**. Ein CISO, der über IT oder Finanzen berichtet, erfüllt sie nicht – unabhängig davon, wie kompetent der CISO ist oder wie oft er Sie informell brieft.



Budget und Stellenbesetzung müssen sich nicht ändern – nur die Linie im Organigramm. Dann ein wiederkehrendes monatliches Meeting mit einer schriftlichen festen Tagesordnung einrichten.

3.7 **3.7** Was bei einer Aufsichtsbehördenprüfung passiert

Sieben Dokumente bilden das Rückgrat Ihrer Prüfungsakte:

1. Artikel 21-Richtlinienpaket (alle elf Richtlinien)
2. Unterzeichnetes Risikoregister mit Restrisikoakzeptanz
3. Vorfallberichte und Lessons Learned
4. Schulungsnachweise (Ihre und die Ihrer Mitarbeiter)
5. CISO-an-Vorstand-Besprechungsprotokolle
6. Asset-Inventar
7. Lieferantenverträge mit den drei kritischen Klauseln

Befund vs. Beobachtung

Befund: Eine Nichtkonformität – etwas, das das Gesetz verlangt und das Sie nicht haben. Löst eine Abhilfeanordnung mit einer Frist aus.

Beobachtung: Liegt unter bewährter Praxis, verstößt aber nicht gegen das Gesetz. Löst keine Anordnung aus.

Wenn die Abhilfe unvollständig ist, wenn der Prüfer zurückkehrt: Der Aufseher eskaliert zu verbindlichen Anweisungen, öffentlicher Bekanntmachung oder Bußgeldern.

3.8 3.8 Szenario – Ransomware trifft Freitagabend

LockerGoga-Ransomware legte 40 Produktionsstandorte über Nacht lahm. Kosten: ca. 60 Mio. €. Gezahltes Lösegeld: null. Die Reaktion funktionierte, weil Ransomware bereits im Risikoregister stand – als sehr wahrscheinlich / sehr schwerwiegend eingestuft – mit einem vom Vorstand genehmigten Reaktionsplan.

Fünf Entscheidungen, die in den ersten 48 Stunden allein dem CEO obliegen:

1. **Krise ausrufen.** Nur Sie können Krisenprozeduren aktivieren.
2. **Notfallausgaben genehmigen.** Forensikdienstleister, externe Rechtsberatung, Incident-Response-Firma.
3. **Eindämmen vor Wiederherstellen.** Wiederherstellen vor der Forensik zerstört die Beweiskette.
4. **Frühwarnung innerhalb von 24 Stunden einreichen.** Melden Sie, was Sie wissen. Geben Sie an, was unklar ist.
5. **Zahlung vorerst ablehnen.** Nicht jetzt – und nur nach rechtlicher Prüfung des Sanktionsrechts.

3.9 3.9 Szenario – Lieferanteneinbruch betrifft Ihre Kundendaten

Die Cl0p-Ransomwaregruppe nutzte eine Zero-Day-Schwachstelle in der MOVEit-Dateiübertragungssoftware aus. Innerhalb von Wochen wurden Daten von über 2.600 Organisationen gestohlen. Einbruch beim Lieferanten. Daten gehörten den Kunden.

Fünf Entscheidungen bei einem Lieferanteneinbruch:

1. Fakten ermitteln: Welche Systeme waren verbunden, welche Daten waren im Transit, über welchen Zeitraum?
2. Vertrag prüfen: Vorfalldenachrichtigungsfristen, Prüfrechte, Entschädigungsregelungen.
3. Eigenen Bericht einreichen – der Bericht des Lieferanten deckt Sie nicht ab.
4. Kunden benachrichtigen, bevor die Presse es tut – nach Artikel 36, Stunden nach Bestätigung der Exposition.
5. Vertragliche Ansprüche verfolgen – *ruhig, nachdem* der Vorfall bewältigt ist.

Geschwindigkeit der Benachrichtigung entscheidet über das Reputationsergebnis. Kunden beurteilen Sie danach, wie schnell Sie sie informiert haben – nicht danach, wessen System angegriffen wurde.

3.10 3.10 Szenario – Phishing-Erfolg: Erheblich oder nicht?

Vier Fragen entscheiden:

1. Hat der Angreifer die Zugangsdaten *verwendet*?
2. Worauf hatten diese Zugangsdaten Zugang? (nur E-Mail vs. Finanzen vs. Kundendatenbanken)
3. Wurden Daten exfiltriert?
4. Überschreitet die finanzielle Auswirkung die DVO-Schwellenwerte?

Bei echter Unsicherheit: **Frühwarnung einreichen**. Der Aufseher bevorzugt „Wir sind nicht sicher, hier ist was wir wissen“ gegenüber Schweigen. Eine Frühwarnung, die hätte vor zwei Tagen gesendet werden müssen, kann nicht nachträglich eingereicht werden.

3.11 **3.11** Szenario – Lückenentdeckung vor der Prüfung

Drei Optionen, wenn Sie zwei Wochen vor einer Prüfung eine Lücke entdecken:

Option	Aktion	Ergebnis
A	Verbergen	Vertuschung entdeckt; Vertuschung ist ein eigenständiger Verstoß
B	Still beheben	Zeitstempel bleiben; sieht wie Vertuschung aus
C	Beheben und offenlegen	Abhilfeanordnung oder Warnung, kein Bußgeld

Bei Option C: sofort beheben, Entdeckung und Zeitplan dokumentieren, dann **schreiben Sie persönlich an den Prüfer** vor der Prüfung – was gefunden wurde, wann, was getan wurde, wie die neuen Kontrollen aussehen.

Wichtige Erkenntnisse

1. Eigene Lücken zu finden ist der erwartete Zustand – Aufseher unterscheiden zwischen gefunden-und-behoben versus verbergen.
2. Eine Lücke zu verbergen oder still zu beheben versagt, wenn die Prüfspur die Geschichte erzählt.
3. Gutgläubige Offenlegung, vom CEO unterzeichnet, mit bereits umgesetzter Lösung, ist die einzige Option, die Ihre Position stärkt.

Kapitel 4

Schutz

Modul 4 – 6 Lektionen

Dieses Modul behandelt die Schutzebene um Ihre persönliche Haftung herum: warum Versicherungen kein Ersatz für Kontrollen sind, was Ihre D&O-Police tatsächlich abdeckt und wie mit den ersten 48 Stunden einer Krise umzugehen ist.

4.1 4.1 Versicherung ist kein Ersatz für Kontrollen

Mondelez wurde von NotPetya-Malware getroffen und erlitt ca. 100 Mio. USD Schaden. Mondelez hielt bei Zurich eine Cyber-Police in dieser Höhe. Zurich lehnte den Anspruch ab mit der Begründung, NotPetya sei ein Kriegsakt gewesen. Es folgten fünf Jahre Rechtsstreit. Vergleich: vertraulich.

Drei Dinge, die Versicherung nicht beseitigt:

- Regulatorische Bußgelder nach Artikel 32 – die meisten Policen schließen sie ausdrücklich aus
 - Das Tätigkeitsverbot nach Artikel 34 – keine Police deckt das ab
 - Die Kundenbenachrichtigungspflicht nach Artikel 36 – die liegt bei Ihnen, unabhängig davon
- Der Prüfer akzeptiert kein Versicherungszertifikat als Nachweis, dass Sie die zehn Maßnahmen umgesetzt haben. **Versicherung zahlt nach dem Vorfall. Der Prüfer überprüft, was Sie vorher getan haben.**

4.2 4.2 D&O-Versicherung – Was sie abdeckt und Cyber-Ausschlüsse

D&O-Versicherung wurde für **unternehmerische Entscheidungsansprüche** konzipiert – die Behauptung, ein Direktor habe eine schlechte Geschäftsentscheidung getroffen. NIS2-Verstöße sind **Verstöße gegen gesetzliche Pflichten** – eine andere Rechtskategorie, die auf der falschen Seite der Grenze liegt, die die meisten D&O-Policen ziehen.

Fragen an Ihr Team

Drei Fragen an Ihren Makler vor jeder Verlängerung:

1. „Enthält unsere aktuelle D&O-Police einen Cyber-Haftungsausschluss?“
2. „Wenn ich persönlich in einem Anspruch des Aufsichters nach Artikel 32(5) genannt werde, zahlt diese Police meine Rechtsverteidigung?“
3. „Was sagt die Police zu Verstößen gegen gesetzliche Pflichten?“

Alle drei Antworten schriftlich, datiert und der Police beigelegt erhalten.

4.3 **4.3** Cyber-Versicherung vs. D&O – Verschiedene Produkte, verschiedener Schutz

	Cyber-Versicherung	D&O-Versicherung
Versicherter	Das Unternehmen	Der Direktor
Deckt	Forensik, Benachrichtigung, Betriebsunterbrechung	Rechtsverteidigung, Vergleiche
Konzipiert für	Cyber-Vorfallkosten	Ansprüche aus Geschäftsentsc.
NIS2-Personalbußgeld?	Nein	Kann Cyber-Ansprüche aussch.

Das gefährliche Szenario: Ein Direktor wird persönlich wegen eines Cybervorfalles verklagt. Die D&O-Police enthält einen ausdrücklichen Cyber-Ausschluss. Die Cyber-Police deckt keine einzelnen Direktoren ab. **Der Direktor ist unversichert.**

Bitten Sie Ihren Makler, eine einseitige Übersicht zu erstellen, welche Schadensszenarien durch welche Police abgedeckt sind.

4.4 **4.4** Häufige Police-Ausschlüsse – Worauf zu achten ist

D&O-Ausschlüsse:

- Der Cyber-Haftungsausschluss (ausdrücklich oder in allgemeiner Sprache versteckt)
- Ausschluss für Vorerkrankungen
- Sanktionsausschluss
- Kriegshandlungsausschluss (nach Mondelez deutlich erweitert)
- Klausel zur mangelnden Sicherheitswartung
- Klausel zur verspäteten Benachrichtigung

Cyber-Versicherungsausschlüsse:

- Vorhandene Schwachstellen und ungepatchte Systeme
- Kriegshandlungs-/Nationalstaatsangriff-Ausschluss (Lloyd's verschärft 2023)
- Einhaltung des Sanktionsrechts
- Regulatorische Bußgelder und Strafen – **fast universell ausgeschlossen**

4.5 **4.5** Die ersten 48 Stunden der Krisenkommunikation

Vier Zielgruppen, in dieser Reihenfolge: Intern zuerst – Aufseher zweite – Kunden dritte – Öffentlichkeit vierte.

Sechs Entscheidungen aus der Maersk-Fallstudie (NotPetya, 2017):

1. **Einen Sprecher** in der ersten Stunde benennen
2. **Innerhalb von zwei Stunden eine Erklärung** herausgeben (bestätigt die Störung, gibt Updatezeit an)
3. **Internes Team briefen** vor jeder externen Erklärung
4. **Frühwarnung einreichen** innerhalb von 24 Stunden
5. **Betroffene Kunden benachrichtigen** nach Artikel 36
6. **Öffentliche Erklärung zuletzt** – nach internem Briefing, Aufsehersbericht und Kundenbenachrichtigung

Der CEO ist selten der Sprecher im Fernsehen, aber **immer der endgültige Genehmiger** jeder externen Erklärung. Rechtliche Überprüfung ist nicht optional.

4.6 4.6 Entscheidungen über Lösegeldzahlungen

Colonial Pipeline zahlte DarkSide ca. 4,5 Mio. USD in Bitcoin. Das Entschlüsselungswerkzeug war so langsam, dass sie ohnehin aus Backups wiederherstellten. Die Zahlung sparte keine Zeit. Der CEO erklärte, eine vorab vereinbarte Politik hätte die Entscheidung verändert. Das Unternehmen hatte vor dem Angriff keine vom Vorstand genehmigte Position zu Lösegeldzahlungen.

Drei rechtliche Einschränkungen bei der Zahlung:

1. **Sanktionsrecht** – die Zahlung an eine sanktionierte Gruppe ist ein Verstoß, auch wenn Sie es nicht wussten. Zuschreibungen sind oft in den ersten Stunden unklar.
2. **Gesellschaftsrecht** – in Deutschland kann eine Lösegeldzahlung, wenn das Entschlüsselungswerkzeug versagt oder Backups verfügbar waren, persönliche Haftung nach Untreue (§266 StGB) auslösen.
3. **Sektorspezifische Regeln** – Finanzdienstleistungen, kritische Infrastruktur, Verteidigung haben zusätzliche Einschränkungen.

Vier Schritte vor jeder Zahlung: CEO-Genehmigung (nicht delegierbar), Rechtsprüfung (Sanktions- und Strafrecht), Koordination mit Strafverfolgungsbehörden, Dokumentation im Vorfallprotokoll.

Die vorab vereinbarte Politik ist das Ergebnis: Ihr Incident-Response-Plan braucht eine vom Vorstand genehmigte Position zu Lösegeldzahlungen, vom CEO unterzeichnet. Etwa 60 % der Zahlungen liefern ein nutzbares Entschlüsselung – oft langsamer als eine saubere Wiederherstellung aus Backups.

Wichtige Erkenntnisse

1. Zahlen garantiert keine Wiederherstellung – etwa 60 % der Zahlungen liefern ein nutzbares Entschlüsselung.
2. Sanktionsrecht greift unabhängig von der Absicht – Sie können den Empfänger nicht immer identifizieren.
3. Die Zahlungsentscheidung vor dem Angriff treffen – eine vorab vereinbarte, vom CEO unterzeichnete Politik verwandelt eine Krisenimprovisation in eine Richtlinienprüfung.

Quiz

F1. Warum lehnte Zurich den Mondelez-Versicherungsanspruch ab?

- A. Die Police war abgelaufen
- B. Zurich argumentierte, NotPetya sei ein Kriegsakt gewesen, was den Kriegshandlungsausschluss auslöste
- C. Mondelez hatte seine Prämie nicht gezahlt
- D. Die Schäden überschritten die Deckungssumme

F2. Welche drei Konsequenzen beseitigt Versicherung nicht?

- A. Betriebsunterbrechung, Datenverlust und Reputationsschaden
- B. Regulatorische Bußgelder, das Tätigkeitsverbot und die Kundenbenachrichtigungspflicht
- C. Rechtskosten, forensische Untersuchung und Incident Response
- D. Personalfuktuation, Lieferkettenstörung und Medienberichterstattung

F3. Was sollten Sie vor einer Lösegeldzahlung tun?

- A. Sofort zahlen, um Störungen zu minimieren
- B. Versicherungsmakler konsultieren und zahlen, wenn gedeckt
- C. CEO-Genehmigung, Rechtsprüfung zu Sanktions- und Strafrecht, Koordination mit Strafverfolgung und Dokumentation
- D. Auf Empfehlung des Aufsehers warten

Kapitel 5

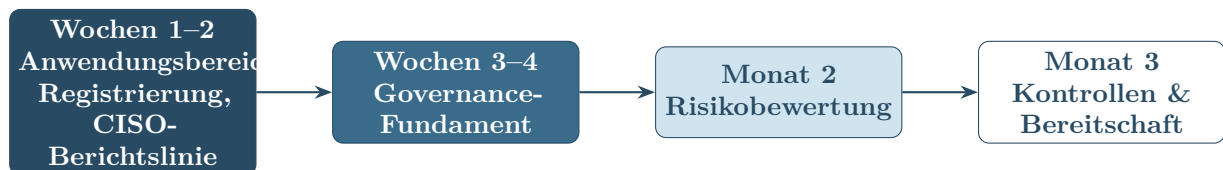
Abschluss

Modul 5 – 2 Lektionen

Der 90-Tage-Aktionsplan, der Wissen in eine verteidigbare Grundlage verwandelt, und was Ihr Abschlusszertifikat bedeutet.

5.1 **5.1** Ihre ersten 90 Tage nach diesem Kurs

Verstehen ist keine Compliance. Der sequenzierte Plan, der Wissen in eine verteidigbare Grundlage verwandelt:



Wochen 1–2:

- Scoping-Bewertung bestätigen (wesentlich oder wichtig)
- Beim BSI registrieren, falls noch nicht erfolgt – verspätete Registrierung ist schlimmer als unvollkommene
- Bestätigen, dass der CISO direkt an Sie berichtet

Wochen 3–4:

- Übergeordnete Informationssicherheitsrichtlinie unterzeichnen (oder erneut unterzeichnen, wenn älter als 12 Monate)
- Monatliches CISO-Briefing einrichten (30 Min., feste Tagesordnung, dokumentiert)
- Bestätigen, dass alle elf Pflichtrichtlinien existieren; Verantwortliche für Lücken zuweisen

Monat 2:

- Asset-Inventar beauftragen oder überprüfen
- Risikoregister beauftragen oder überprüfen
- Restrisikoakzeptanz unterzeichnen (das Dokument, das die meisten CEOs nicht vorlegen können)

Monat 3:

- Die zehn Maßnahmen mit Ihrem CISO durchgehen – nach den Nachweisen fragen, nicht nach der Beschreibung
- Incident-Response-Plan testen (Tischübung, dokumentiert)
- Top-Lieferantenverträge auf drei Klauseln überprüfen
- Jährlichen Managementreview einplanen

Laufender Rhythmus:

- Monatlich: CISO-Briefing
 - Jährlich: Richtlinien-Neuunterzeichnung, Risikoregisterbewertung mit Restrisikoakzeptanz, Managementreview mit Protokoll
 - Alle drei Jahre: Schulungsauffrischung für das Leitungsorgan
- Compliance ist kein Projekt. Der 90-Tage-Plan baut die Grundlage. Der Rhythmus erhält sie.

Wichtige Erkenntnisse

1. Die ersten zwei Wochen drehen sich um Anwendungsbereich, Registrierung und die CISO-Berichtslinie.
2. Bis Tag neunzig: übergeordnete Richtlinie unterzeichnen, Risikoregister mit Restrisikoakzeptanz, zehn Maßnahmen mit Nachweisen durchgehen.
3. Compliance ist kein Projekt – der 90-Tage-Plan baut die Grundlage; der monatliche und jährliche Rhythmus erhält sie.

5.2 5.2 Abschlusszertifikat

Wenn Sie den Kurs abschließen, erhalten Sie ein **Abschlusszertifikat** mit Ihrem Namen, Ihrer Einrichtung, dem Kurstitel, dem Abschlussdatum, den abgedeckten NIS2-Artikeln und der im Kurs verbrachten Zeit.

Das Zertifikat ist Ihr Schulungsnachweis. Wenn ein Prüfer fragt, wie Sie die Schulungspflicht nach Artikel 20(2) erfüllt haben, ist das Zertifikat das erste Dokument, das Sie vorlegen.

Heben Sie es in Ihrer Compliance-Dokumentation auf – im selben Ordner wie Ihre unterzeichnete Sicherheitsrichtlinie, das Risikoregister und den Incident-Response-Plan. Diese vier Dokumente zusammen bilden das Rückgrat Ihrer Prüfungsakte.

Drei Aufgaben für die nächsten zwei Wochen:

1. Treffen Sie Ihren CISO. Bringen Sie die Liste der zehn Maßnahmen aus Modul 2. Stellen Sie zwei Fragen pro Maßnahme: Was haben wir eingerichtet, und können Sie mir den Nachweis zeigen?
2. Finden Sie Ihre aktuelle unterzeichnete Sicherheitsrichtlinie. Prüfen Sie das Datum. Prüfen Sie, wessen Name darauf steht. Prüfen Sie, ob die darin referenzierte Risikoanalyse existiert und aktuell ist.
3. Verfolgen Sie die CISO-Berichtslinie im Organigramm. Wenn jemand zwischen dem CISO und dem Leitungsorgan steht, beginnen Sie das Umstrukturierungsgespräch.

Wichtige Erkenntnisse

1. Das Abschlusszertifikat ist der Schulungsnachweis für den Prüfer – es dokumentiert Ihre Teilnahme, den behandelten Inhalt und die aufgewendete Zeit.
2. Bewahren Sie das Zertifikat zusammen mit Ihrer unterzeichneten Sicherheitsrichtlinie, dem Risikoregister und dem Incident-Response-Plan auf.
3. Drei Aufgaben in den nächsten zwei Wochen: CISO treffen und die zehn Maßnahmen durchgehen, unterzeichnete Sicherheitsrichtlinie lesen und verifizieren, CISO-Berichtslinie nachverfolgen.

Anhang A

Antwortschlüssel

Jeder Eintrag zeigt die Lektionsnummer, die Fragennummer und den korrekten Antwortbuchstaben.

Lektion 1.1

F1: B

F2: C

F3: B

F4: C

Lektion 1.2

F1: B

F2: B

F3: C

Lektion 1.3

F1: B

F2: B

F3: C

F4: B

Lektion 1.4

F1: B

F2: B

F3: B

Lektion 1.10

F1: B

F2: B

Lektion 2.6

F1: C

F2: B

Lektion 2.15

F1: B

F2: B

Lektion 4.6

F1: B

F2: B

F3: C

Anhang B

Die nicht delegierbare Checkliste

Die elf Dokumente, nach denen ein Prüfer fragen wird. Als Selbstbewertung nutzen.

#	Dokument	Erledigt?	Zuletzt aktualisiert
1	Übergeordnete Informationssicherheitsrichtlinie, in Ihrem Namen mit Datum unterzeichnet	☐	
2	Unterzeichnete Restrisikoakzeptanz (die, die die meisten CEOs nicht vorlegen können)	☐	
3	Genehmigung des Sicherheitsbudgets	☐	
4	Krisenmanagementplan mit Ihrem Namen als Krisen-ausrufer	☐	
5	Vorab vereinbarter Artikel 23-Meldungsentscheidungsprozess	☐	
6	Kundenbenachrichtigungsvorlage und Genehmigungskette	☐	
7	Vorab vereinbarte Politik zu außerordentlichen Zahlungen (Ransomware)	☐	
8	Genehmigungsprotokoll für externe Kommunikation in Krisen	☐	
9	Beauftragungsbefugnis für Forensik / Rechtsberatung definiert	☐	
10	Eskalationsprotokoll für Konflikte zwischen Sicherheit und Geschäftsprioritäten	☐	
11	Jährliches Managementreview-Protokoll mit Ihrer Unterschrift	☐	

Anhang C

Die elf Pflichtrichtlinien

#	Richtlinie	Genehmiger	Erledigt?
1	Informationssicherheitsrichtlinie (übergeordnet)	CEO	☐
2	Risikomanagement	Senior	☐
3	Vorfallbehandlung	Senior	☐
4	Lieferkettensicherheit	Senior	☐
5	Sicherheitstests	Senior	☐
6	Wirksamkeitsbewertung	Senior	☐
7	Kryptografie	Senior	☐
8	Zugangskontrolle	Senior	☐
9	Privilegierte Konten	Senior	☐
10	Informations- und Asset-Handling	Senior	☐
11	Wechselmedien	Senior	☐

Senior = jemand mit ausreichender Entscheidungsbefugnis; nur #1 erfordert die CEO-Unterschrift.

Anhang D

Die BSI-Leitfragen für Geschäftsführer

Ausdrucken. Jede bewerten: **S** = sicher, **H** = mit Hilfe, **N** = kann ich nicht beantworten.

#	Frage	S / H / N
1	Weiß ich, ob mein Unternehmen unter NIS2 fällt, und verstehe ich den Anwendungsbereich?	
2	Erfüllen unsere Risikomanagementmaßnahmen die gesetzlichen Anforderungen und sind dokumentiert?	
3	Kann ich einen erheblichen Vorfall korrekt klassifizieren und rechtzeitig melden?	
4	Sind wir korrekt beim Aufseher registriert und halten wir die Registrierung aktuell?	
5	Verstehe ich meine persönlichen Pflichten, Schulungsanforderungen, Haftung und Sanktionen?	
6.1	Ist unsere Risikoanalyse aktuell und auf aktuelle Bedrohungen ausgerichtet?	
6.2	Haben wir einen getesteten Incident-Response-Plan?	
6.3	Können wir aus einem Backup wiederherstellen und ist unser Krisenmanagement getestet?	
6.4	Wird die Lieferantensicherheit überprüft und aktiv gemanagt?	
6.5	Ist Sicherheit in Beschaffung, Entwicklung und Wartung eingebaut?	
6.6	Messen wir die Wirksamkeit unserer Sicherheitskontrollen?	
6.7	Führen wir Cyberhygiene-Programme und Mitarbeiterschulungen durch?	
6.8	Setzen wir Kryptografie und Verschlüsselung dort ein, wo es erforderlich ist?	
6.9	Managen wir Personalsicherheit, Zugangskontrolle und Asset-Management?	
6.10	Verwenden wir MFA und gesicherte Kommunikation?	
7	Deckt unsere Risikoanalyse alle Assets, Bedrohungen und Schadensarten ab?	
8	Bewerten wir, wie jedes Risiko CIA und finanzielle Stabilität beeinflusst?	
9	Berücksichtigen wir sektorspezifische Anforderungen und kritische Geschäftsprozesse?	
10	Führen wir Szenarioübungen durch und habe ich persönlich an einer teilgenommen?	

Anhang E

Glossar der Schlüsselbegriffe

Allgefahrenansatz

Anforderung aus Artikel 21(1), Systeme vor jeder Bedrohung zu schützen – nicht nur vor Cyberangriffen, sondern auch vor physischen Bedrohungen, Umweltereignissen, Lieferantenausfällen, Insider-Bedrohungen und menschlichem Versagen.

Artikel 20(1)

Die persönliche Pflicht des Leitungsorgans, Cybersicherheitsmaßnahmen zu genehmigen, ihre Umsetzung zu überwachen und für Verstöße haftbar zu sein.

Artikel 20(2)

Die persönliche Schulungspflicht: Jedes Mitglied des Leitungsorgans muss an Cybersicherheits-schulungen teilnehmen. Nicht delegierbar.

Asset-Inventar

Eine vollständige, aktuelle Liste von allem, wovon das Unternehmen für seinen Betrieb abhängt – Server, Software, Daten, Mitarbeiter, Lieferanten und Prozesse.

BSI

Bundesamt für Sicherheit in der Informationstechnik – Deutschlands nationale Cybersicherheitsbehörde und zuständige NIS2-Behörde.

BSIG

IT-Sicherheitsgesetz – Deutschlands nationale Umsetzung der NIS2-Richtlinie.

CIA-Triade

Vertraulichkeit (Daten nur für Berechtigte zugänglich), Integrität (Daten korrekt und unverfälscht), Verfügbarkeit (Systeme verfügbar wenn benötigt).

DVO

Durchführungsverordnung (EU) 2024/2690, unmittelbar anwendbar in allen 27 Mitgliedstaaten, legt detaillierte technische Anforderungen fest einschließlich Schwellenwerten für erhebliche Vorfälle und den elf Pflichtrichtlinien.

Erheblicher Vorfall

Definiert in DVO 2024/2690: finanzieller Verlust von mehr als 500.000 € oder 5 % des Umsatzes (je niedriger), Exfiltration von Betriebsgeheimnissen, Tod, schwerwiegender Gesundheitsschaden oder böswilliger Zugang mit schwerwiegender Störung.

Geschäftsauswirkungsanalyse (BIA)

Dokument, das technische Risikokategorien in Geschäftszahlen übersetzt – Wiederherstellungsziele und Geschäftsfolgen – für jedes kritische Asset.

Joiner-Mover-Leaver-Prozess

Der HR-IT-Prozess für den gesamten Beschäftigungslebenszyklus – Zugang bei Eintritt erteilt, bei Rollenwechsel angepasst, bei Austritt gesperrt.

Leitungsorgan

Der rechtliche Begriff für das Leitungsteam: Geschäftsführer, Vorstandsmitglieder, leitende Direktoren. Jedes Mitglied trägt dieselben Pflichten nach NIS2.

Legalitätspflicht

Ein Direktor muss geltendes Recht einhalten. Kein unternehmerisches Ermessen ist erlaubt, ob eine gesetzliche Pflicht zu befolgen ist.

Managementreview

Formaler jährlicher dokumentierter Review des gesamten Sicherheitsprogramms nach BSI-Standard 200-1, Abschnitt 7.4. Muss ein unterzeichnetes Protokoll hervorbringen.

Nicht delegierbar

Kann nicht an jemand anderen übertragen werden. Die Schulungspflicht, die Genehmigungspflicht und die elf Checklistenpunkte sind alle nicht delegierbar.

Patch-SLA

Eine schriftliche Frist für die Anwendung von Sicherheitspatches, nach Schwachstellenschwere gruppiert (z. B. kritisch: 72 Stunden, hoch: 30 Tage).

Proaktive Aufsicht

Der Aufseher kann wesentliche Einrichtungen jederzeit ohne Anlass prüfen.

Reaktive Aufsicht

Der Aufseher prüft wichtige Einrichtungen nur bei einem Auslöser – Vorfall, Beschwerde oder Erkenntnissen.

Restrisikoakzeptanz

Was nach Anwendung von Kontrollen verbleibt. Muss formal vom Leitungsorgan akzeptiert werden (DVO 2024/2690, Anhang 2.1.1).

Risikobereitschaft

Das Maß an Risiko, mit dem das Unternehmen insgesamt leben will. Der CEO setzt diese Grenze.

RPO / RTO

Recovery Point Objective (maximaler akzeptabler Datenverlust, gemessen in Zeit) und Recovery Time Objective (maximale akzeptable Zeit zur Wiederherstellung des Dienstes).

Stand der Technik

Aktuelle Best Practice gemäß veröffentlichten Standards zum Zeitpunkt der Prüfung. Kontrollen müssen überprüft und aktualisiert werden, nicht nur einmalig umgesetzt.

Tischübung

Eine schriftliche Probe des Incident-Response-Plans gegen ein realistisches Szenario. Muss mindestens jährlich mit dokumentierten Ergebnissen durchgeführt werden.

Wesentliche Einrichtung

Unternehmen des Anhang-I-Sektors (Energie, Verkehr, Banken usw.) – unterliegt proaktiver Aufsicht.

Wichtige Einrichtung

Unternehmen des Anhang-II-Sektors (Chemikalien, Fertigung, Lebensmittel usw.) – unterliegt reaktiver Aufsicht.

Über NISD2

NISD2 (www.nisd2.eu) ist eine kostenlose NIS2-Compliance-Plattform für von der NIS2-Richtlinie betroffene Unternehmen. Sie bietet strukturierte Dokumentation, Prüfprotokolle, Lieferantenregister und das in diesem Buch beschriebene Schulungszertifikat für Leitungsorgane.

Diese PDF ist ein Begleitmaterial zum Online-Kurs. Die Online-Version umfasst:

- Interaktive Quizze mit sofortigem Feedback
- Bei Bestehen ausgestelltes Abschlusszertifikat
- Prüfprotokoll, das Ihre Schulung für Aufseher dokumentiert
- Deutsche und englische Versionen aller Inhalte

www.nisd2.eu



NISD2